

Role Based Access Control

SOX / ICFR engagement

1 · The three roles

Role	What they do
Auditor	Does the testing and decides whether a control works
Control owner	Runs the control day to day, and fixes it when it breaks
Reviewer	Checks the auditor's work and signs it off

The same person can own a control in two ways, as the owner of the control itself or as the owner of the process around it. Either one counts as owning it.

A problem found during testing is called a **deficiency**. The file holding all the evidence for one control is its **audit file**.

2 · What each role can do

Auditor

Can	Cannot
Set up the audit: its dates, which companies it covers, and which controls are tested	Agree how serious a deficiency is. That is the reviewer checking the auditor's judgement
Set the money limits that decide how serious a problem counts as	Write or edit the fix plan. The auditor advises, the owner writes it
Approve the control list, add a control, or mark one as important	Say that the owner's fix is ready to be tested again
Decide what each control will be checked against	Sign an audit file second, after their own signature
Test whether a control is built well: gather documents, check each point, decide	Close a deficiency, or raise and settle a written challenge
Choose which transactions are in play, prove the report they came from, and pick the ones to test	Sign the audit off as reviewer
Record every result, disagree with a result and say why, and decide whether the control worked	

Judge how serious a deficiency is, judge the fix plan, and test the fix	
Mark a control as impossible to test right now, and later clear or escalate that	
Sign an audit file first, sign the audit off first, and unlock a finished control by giving a reason	

Control owner

Can	Cannot
Answer a request for documents and upload what they have	Decide anything about whether the control worked
Confirm in writing that a check was done, with evidence attached	Change what their own control is checked against. Writing your own exam is not evidence
Write the fix plan: what will be done, by whom, by when	Judge how serious a deficiency is
Upload proof of the fix and hand it back for testing	Test their own fix, or close a deficiency
Disagree with a finding, or ask the audit team a question	Reopen a closed deficiency, or change what the audit covers
Open a control they own	Open a control they do not own, by any route, including a direct link

The fix plan can be edited only while it is still with the owner. Once it goes back to the auditor, it is frozen.

Reviewer

Reads everything and signs. **Cannot change anything in the testing.**

Can	Cannot
Read every control, audit file, deficiency and history	Upload evidence, record a result, or decide whether a control worked
Agree how serious a deficiency is, or send it back with a reason	Choose which transactions are tested, or which ones are picked
Raise a written challenge, then accept or reopen the auditor's answer	Judge how serious a deficiency is in the first place, or judge the fix plan
Sign an audit file second, once the auditor has signed it	Sign while a challenge on that control is still open
	Write a fix plan

Send a finished control back to the auditor, which reopens both decisions but keeps the test results	
Close a deficiency once its fix has passed testing	Set up or change an audit. That is the auditor's job
Sign the audit off last, and reopen a closed deficiency by giving a reason	Sign the audit off first

3 · What each role sees

Role	Tabs inside an audit	Where they land
Auditor	Dashboard, Control Library, Deficiency management, Configuration	The dashboard
Reviewer	The same four	The dashboard, plus a list of what is waiting on them
Owner	Three only: Overview, Control Library, their own deficiencies	A task list, not a dashboard

The owner keeps a deficiency view on purpose. Writing the plan and doing the fix are their jobs, and someone who cannot reach their own work cannot do it. The list only shows their controls.

What the owner is not shown

Screen	What the owner gets instead
Control Library	Only controls in their name, and the count says so
A control	Their documents and what is still outstanding, then a line saying the testing and its result are not shown here. The later steps are simply absent
History of actions	Their own actions, plus document requests and what they sent back
The audit file	A short summary of what they need to fix, built only from what they are allowed to see
How many items get tested, and why	Nothing. That is the audit team's method

The rule the product follows, and the right one: **whatever a role cannot do is not on the screen at all, rather than greyed out.**

4 · Locks that stop everyone

Two locks have nothing to do with roles. They stop **everybody**, the auditor included, so that a signed decision cannot quietly change afterwards.

Lock	When it applies	How it opens
Control lock	The moment a control is decided	The auditor unlocks it with a reason, or the reviewer sends it back with a reason
Audit lock	The moment the audit is signed off by the reviewer	It does not. This one is permanent

Both are checked at the point something is saved, so they hold whichever screen the change came from.

5 · Who holds a deficiency, and when

Work passes back and forth so that no two steps in a row sit with the same person.

Stage	With	Doing
Found	Auditor	Writing down what went wrong, then judging how serious it is
Rating check	Reviewer	Agreeing how serious it is, before any fix starts
Planning	Owner	Writing the fix plan, or rewriting a rejected one
Plan check	Auditor	Checking the plan actually addresses the cause
Fixing	Owner	Doing the work and uploading proof
Testing the fix	Auditor	Testing again on fresh items
Final check	Reviewer	Reading the proof and closing it
Closed	Nobody	The auditor or the reviewer can reopen it by giving a reason

The rating check blocks everything. Nothing else can happen until the reviewer agrees or sends it back, because a plan written for the wrong level of seriousness is wasted work.

A written challenge moves the work too. While one is open the control sits with the auditor, and once answered it sits with the reviewer.

The screen names **the person** holding it, not the role. You cannot chase a role for an answer.